

This chapter covers the following topics related to Objective 4.3 (Given a scenario, apply network security features, defense techniques, and solutions) of the CompTIA Network+ N10-009 certification exam:

- Device hardening
  - Disable unused ports and services
  - Change default passwords
- Network access control (NAC)
  - Port security
  - 802.1X
  - MAC filtering
- Key management
- Security rules
  - Access control list (ACL)
  - Uniform Resource Locator (URL) filtering
  - Content filtering
- Zones
  - Trusted vs. untrusted
  - Screened subnet

CHAPTER 20

Network Security Features

While there are numerous security tools available to us today, this chapter examines some of the most popular. We will discuss the importance and techniques involved in device hardening. We then examine network access control (NAC), key management, security rules, and zones. These topics help you build a strong foundation for further network security studies. Note that some of these topics have been touched on in previous chapters, but in this chapter, they receive the security-centric focus they deserve.

Foundation Topics

Device Hardening

For a long time, many network vendors emphasized using a defense-in-depth strategy. And while they would still stand behind this approach, today plenty of other security initiatives are promoted, such as zero trust. If you think about the defense-in-depth concept for a moment, you'll realize the importance of network ***device hardening*** in this strategy. After all, it's wise to tightly secure the network devices themselves in an attempt to build a very secure network.

In addition, network (device) hardening is an excellent idea because many devices ship from the manufacturer with default configurations that can be quite dangerous. For example, you might receive a network router that has a web server process enabled inside it. This web server software might permit HTTP (not HTTPS) connections, and there may be no access control list or firewall of any kind protecting this web server. Perhaps this security vulnerability is meant to permit web-based management of the device. Your security policy probably does not permit such a vulnerability. Hardening this device by disabling or even eliminating that web server is an excellent idea. In fact, because you should always try to adhere to your security policy, in this scenario, the web server must be uninstalled or at least disabled.

Best Practices

While the hardening of a network through the hardening of its network devices can be a daunting task, the great news is that there are many standard best practices in this regard. Just remember that whenever you see a list like this, you should be prepared to encounter plenty of best practices that will not be applicable for your particular network or your particular network device.

The following is an impressive list of network hardening techniques you should at least consider:



- **Change default passwords:** At a very minimum, you should always do this step! The first thing an attacker is likely to do as an initial step in a larger-scale attack is try using default username and password credentials to access network devices. Plenty of websites provide lists of default username and password credentials for common systems from popular vendors. If you take none of the other steps described in this chapter, at least take this one as it is crucial.

- **Avoid using common passwords and usernames on devices:** Avoid using usernames like **admin** and passwords like **pasword123**. You also need to follow your own enforced password complexity and length policy. Today, it is recommended that passwords be at least 8 to 12 characters and include a certain combination of special characters, numbers, and upper- and lowercase letters.

NOTE Always be sure to keep up on the latest industry recommendations. For example, NIST's "Digital Identity Guidelines" includes the latest password recommendations. This document is available at https://pages.nist.gov/800-63-3/sp800-63b.html.

- **Upgrade firmware:** By installing updated firmware, you gain new functionality on a device, and oftentimes the device gets much-needed security patches and enhancements. Figure 20-1 shows the firmware upgrade process for a small office/home office (SOHO) wireless router.

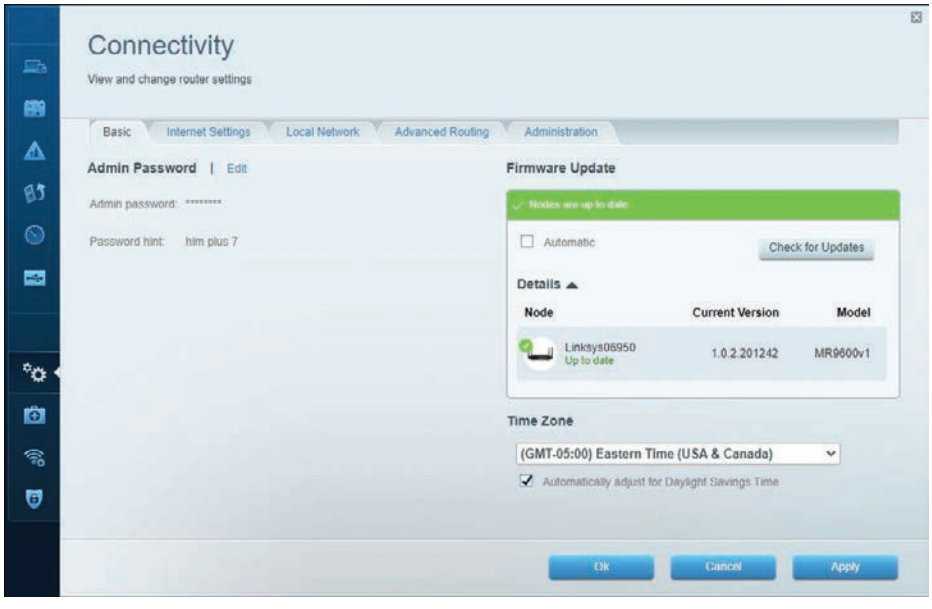


Figure 20-1 Upgrading the Firmware on a SOHO Wireless Router

- **Patch and update:** Just as your firmware needs consistent attention to patches and updates, so do your operating system and applications. Many network devices from popular vendors today are so sophisticated with their OS that they can run plug-in types of applications or even full-blown apps. Patches and updates might bring advanced features to a device.

- **Disable unneeded network services:** Modern network devices tend to have many network services enabled by default. To reduce the attack surface, you should trim off any unnecessary services by disabling them. Reducing the attack surface by not running services means that there is less that the attacker can target. Attackers commonly target Bluetooth and remote desktop services as methods of carrying out access for their subsequent attacks.
- **Disable unneeded switch ports:** Ports on switches that are not connected to anything need to be shut down. One primary reason to disable unneeded switch ports is that if someone gains physical access to a network switch and connects to a switch port, you want to ensure that the person cannot access the network through that port. You can use port blocking as well as physical security practices to prevent such access.
- **Use secure protocols:** Use secure protocols over unsecure protocols whenever possible. For example, use Secure Shell (SSH) rather than the insecure Telnet for remote management using terminals. Other unsecure protocols to remember include HTTP, SLIP, FTP, Trivial FTP (TFTP), and Simple Network Management Protocol Version 1/2 (SNMPv1/v2).
- **Secure SNMP:** Be sure to use the security features of the relatively new SNMP Version 3. "SNMP means Security Is Not My Problem" does not apply to Version 3 of SNMP, which provides encryption.
- **Generate new keys/credentials:** Rotate, rotate, and then rotate again those important credentials that are used to guard your corporate systems and data. Fortunately, today there are many tools that enterprises can turn to for assistance in this area. IT departments can call upon cloud-based solutions for key management, and corporate employees can use password management systems to help ensure strong and rotated network passwords.
- **Ensure spanning tree protections:** If you are stuck with Spanning Tree Protocol (STP) in your network, you need to be sure to use any protections offered by a network device. These protections might include Root Guard, Bridge Protocol Data Unit (BPDU) Guard, and Flood Guard.
- **Enable DHCP snooping:** This involves preventing rogue DHCP servers and DHCP pool exhaustion attacks by restricting ports from accepting certain DHCP messages.
- **Use VLAN segmentation:** Doing so inherently protects systems from accidental or malicious attacks from systems in other broadcast domains. VLAN segmentation also forces inter-VLAN communications to pass through a router, allowing you to easily enforce security policy and security checks on the traffic.

- **Use Router Advertisement (RA) Guard:** This helps protect against attacks in IPv6 environments, where routers can advertise the network prefix information to end systems. These end systems can configure their own unique host IDs. Therefore, you can address end systems without requiring DHCP implementation. While these types of features are excellent, you need security controls such as RA Guard to make sure these features are not exploited.
- **Use DAI:** *Dynamic ARP inspection (DAI)* is a security mechanism that guards against MAC address spoofing. It can pair nicely with port security.
- **Use CoPP:** *Control plane policing (CoPP)* is an excellent security feature that can control the rate of packets to and from the control plane of a network device. Think about life without CoPP: Attackers could easily cause denial of service (DoS) on a network device by simply flooding fake Border Gateway Protocol (BGP) updates to the device (or updates from another control plane protocol).
- **Use private VLANs:** You will often implement networks for special types of deployments. For example, say that you are creating a network to be shared by a row of stores in a shopping mall. Each store needs to be segmented from every other store. *Private VLANs* are excellent for such a design. Each store can have its own private VLAN. All of these private VLANs can reach the Internet, but they cannot enter the other private VLANs. All of the VLANs in this case can be in the same IP subnet. This type of topology would confuse an attacker who is unaware of the private VLAN feature. The attacker would see that the systems are clearly in the same IP subnet, but they would be unable to communicate with each other. This would be very strange in a VLAN topology.
- **Change the default VLAN:** Most network devices that offer switch ports place all of these ports in a default VLAN. For example, Cisco Systems switches have all ports in VLAN 1 by default. Attackers know this and seek out ports in the default configuration to try to exploit them.
- **Use *access control lists (ACLs)*:** ACLs are a set of rules used to control network traffic and restrict access to network resources by specifying which users or system processes can access certain resources and the operations they are allowed to perform. Use ACLs wherever possible to help strengthen security. For example, a network device might actually be using the built-in web server for network management. If this device offers an ACL feature to protect the internal web server from unauthorized access, you should take advantage of this feature.
- **Use role-based access:** Consider using *role-based access control* (*RBAC*) by creating groups or roles on network devices. You can map these groups to

different permission levels. This would allow you to permit junior engineers read-only access to devices to help you with monitoring. At the same time, you can have groups with much higher levels of privileges to help with configuration and optimization.

- **Use firewall rules:** Many network devices have full-blown firewall services built in. It is important to consider how a firewall operates with traffic that does not match any permit statement in the firewall configuration. Does the device have an *implicit deny* rule for all of this traffic, or do you need to configure an *explicit deny* for this traffic? As traffic passes through the firewall rules, it is permitted or denied based on those rules. When it reaches the end of the explicitly stated rules, is it dropped due to an implicit deny? Or do you need to configure an explicit deny rule at the end? The most common configuration is to have an implicit deny in place for all the unmatched traffic in the firewall rules.

NOTE For a firewall that consists of all DENY entries, you might need to add an explicit *permit all* entry at the end of the rules to override an implicit *deny all*.

Network Access Control (NAC)

There are a number of security best practices to consider for our wired networks, our wireless networks, and the ever-growing *Internet of Things (IoT)*. Notice that most of these are in the category of ***network access control (NAC)***. It is the job of NAC to manage and control the access of devices to a network, ensuring that only authorized and compliant devices can connect. Here are some popular techniques:

Key Topic

- **Use *port security*:** Port security is a network security feature that helps control access to specific ports on a switch based on the MAC address of the device requesting access. It prevents unauthorized devices from connecting to the network by allowing only approved devices to use those ports. Locking down switch ports to MAC addresses is a good first step in hardening a network. Doing so guards against MAC flood attacks nicely, but note that the network is still vulnerable to MAC spoofing attacks.
- **Use *MAC filtering*:** MAC filtering, which is similar to port security, is important in a wireless environment. With MAC filtering, you lock down access to the Wi-Fi network by allowing only specific MAC addresses.
- **Use wireless client isolation:** Wireless client isolation is a security feature that prevents wireless clients from communicating with one another. This feature is useful for guest and BYOD wireless networks.

- **Use guest network isolation:** If you do not care if your guest Wi-Fi nodes can reach each other, you might consider implementing isolation for the entire guest Wi-Fi network. This is a very common practice. The guest Wi-Fi permits the nodes inside it to access the public Internet, but it does not permit any of the network devices in the enterprise hosting the guest Wi-Fi.
- **Rotate and secure the use of strong pre-shared keys (PSKs):** If you are relying on PSKs in your Wi-Fi security environment, be sure to rotate and protect these credentials just as you do with the more traditional passwords for user accounts in your enterprise. See Chapter 11, "Configure Wireless Devices and Technologies," for more details about PSKs.
- **Use Extensible Authentication Protocol (EAP):** EAP has become the de facto standard for carrying security credentials in a Wi-Fi network. In the case of the popular ***802.1X***, the EAP client (called the *supplicant*) sends the security credentials to the WLC wrapped in an EAP packet. The WLC wraps this packet in a RADIUS packet and sends the information to an authentication server on the network. This system checks the security credentials and then instructs the WLC whether it should permit the device or user on the network.
- **Use geofencing where needed:** This technology often uses the Global Positioning System (GPS) or radio frequency identification (RFID) to define geographical boundaries. *Geofencing* allows you to define triggers so that when a device enters (or exits) the boundaries defined by the administrator, an alert is issued. Geofence virtual barriers can be active or passive. An active geofence requires an end user to opt in to location services and requires a mobile app to be open. Passive geofences are always on; they rely on Wi-Fi and/or cellular data instead of GPS or RFID and can work in the background. For example, say that a hospital keeps patient information on tablets that the hospital distributes to staff. If these tablets travel beyond the geofence, an administrative alert can trigger.
- **Use captive portals:** As introduced in Chapter 11, *captive portals* can obtain information about guests that are attempting to access guest networks or other network resources. With this approach, you send the user to a web page to enter credential information and/or accept agreements on usage. Most public networks, including Wi-Fi hotspots, use a captive portal, which requires users to agree to some condition before they use the network or Internet.
- **Control IoT access:** You need to be concerned about breaches of security in your IoT infrastructures, which often rely on your Wi-Fi (or at least portions of it). Therefore, many of the other best practices listed in this section are appropriate for IoT infrastructures. It is a good idea to consistently update

your IoT devices for the new security enhancements that inevitably come. You should also segment the IoT traffic as much as possible in the enterprise.

Other Network Security Features

Among the numerous other network security features, here are just some of the more popular features in use today. Notice that many of these are key topics for the CompTIA Network+ exam:

- ***Key management*:** Key management involves the processes and systems used to create, distribute, store, and manage cryptographic keys. These keys are essential for encrypting and decrypting data, ensuring that only authorized parties can access sensitive information. Effective key management ensures that keys are kept secure, regularly updated, and properly destroyed when no longer needed. This helps prevent unauthorized access and protects data from being compromised, playing a crucial role in maintaining the overall security of a network. Public cloud providers are now offering key management as one of the many managed services that are available. This is a clearcut attempt to lure to the cloud those IT departments buckling under the network security workloads often required today.
- **Security rules:** In addition to access control lists (described earlier in this chapter), there are numerous other security rules that might assist the modern network engineer. For example, an organization might engage in ***Uniform Resource Locator (URL) filtering***. URL filtering is a network security measure that restricts access to certain websites based on their URLs, allowing organizations to block or allow specific web content to protect users from harmful sites and enforce Internet usage policies. Another example of a security rule approach is ***content filtering***. Content filtering is a technique used to monitor and control the types of content that can be accessed or transmitted over a network. It works by examining data such as emails, web pages, and files to block or allow specific content based on predefined criteria, helping to protect users from inappropriate, harmful, or malicious material and ensuring compliance with organizational policies.
- **Zones:** Today, it is quite common for network security engineers to divide the network into zones to benefit the overall security posture. For example, a network might be divided into ***trusted zones*** and ***untrusted zones***. Trusted zones are network segments that contain resources and systems deemed secure and reliable, typically with strict access controls and security measures in place. Untrusted zones, on the other hand, are network segments that include external or less secure networks, such as the Internet or guest networks, where the risk of threats is higher. By separating these zones, organizations can

implement different security policies and controls, ensuring that sensitive data and critical systems in the trusted zones are protected from potential threats originating from the untrusted zones. Yet another type of zone that might be identified is a ***screened subnet***. A screened subnet, also known as a demilitarized zone (DMZ), is a network segment that sits between an internal trusted network and an external untrusted network, providing an additional layer of security by isolating and protecting internal systems from external threats while allowing controlled access to public-facing services. Figure 20-2 shows an example of a screened subnet.

Key Topic

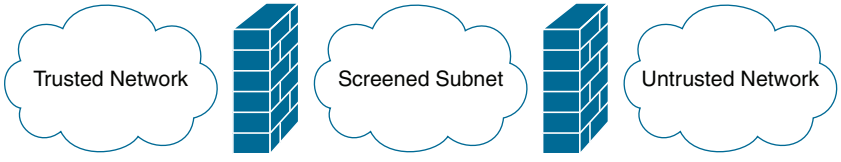


Figure 20-2 An Example of a Screened Subnet

Real-World Case Study

Acme, Inc. has decided to perform a security audit of the network. As part of this audit, Acme, Inc. is finding many improvements that can be made very easily. Most of these center on network and device hardening.

Acme, Inc. has identified many services running on network nodes that can safely be disabled. An audit of network access also revealed many unused network ports that can be disabled. Also, Acme identified an area of the organization where the password policy in effect was not appropriately following best practices.

Finally, Acme, Inc. is changing a portion of the network design where in-band network management traffic was discovered. This traffic, if captured, would have revealed several parameters regarding the network configuration that are considered private. This management traffic is now flowing through an encrypted tunnel so that the chance of an on-path attack is now greatly reduced.

Summary

Here are the main topics covered in this chapter:

- This chapter covered best practices for hardening a network and network devices.

- This chapter discussed many security features related to network access controls in networks today.
- This chapter also presented various other security measures commonly found in secure networking, including key management, the use of security rules, and the use of security-based zones in the network.

Exam Preparation Tasks

Review All the Key Topics

Review the most important topics from this chapter, noted with the Key Topic icon in the outer margin of the page. Table 20-1 lists these key topics and the page number where each is found.

Key Topic

Table 20-1 Key Topics for Chapter 20

Key Topic Element	Description	Page Number
List	Network hardening best practices	476
List	Network access control techniques	480
Figure 20-2	An Example of a Screened Subnet	483

Define Key Terms

Define the following key terms from this chapter and check your answers in the Glossary:

802.1X, access control list (ACL), content filtering, device hardening, key management, MAC filtering, network access control (NAC), port security, screened subnet, trusted zone, Uniform Resource Locator (URL) filtering, untrusted zone

Additional Resources

Hardening Network Devices: https://media.defense.gov/2020/Aug/18/2002479461/-1/-1/0/HARDENING_NETWORK_DEVICES.PDF

What Is RBAC?: https://digitalguardian.com/blog/what-role-based-access-control-rbac-examples-benefits-and-more

Review Questions

The answers to these review questions appear in Appendix A, "Answers to Review Questions."

1. Your primary concern when hardening your network is the fact that you are vulnerable to several DoS attacks that involve your IGP and EGP protocols. What hardening technique addresses this challenge most directly?
   a. Control plane policing
   b. Geofencing
   c. SNMP
   d. Dynamic ARP inspection

2. What protocol makes 802.1X possible?
   a. SSH
   b. Telnet
   c. SNMPv3
   d. EAP

3. What device hardening technique might be found in a row of stores in a shopping mall to ensure that the different stores are segmented from each other?
   a. Default VLAN
   b. DHCP snooping
   c. Private VLAN
   d. Dynamic ARP inspection

4. Which of the following is not a network hardening best practice?
   a. Use SNMPv3
   b. Disable unneeded services
   c. Implement role-based access
   d. Change to default passwords

5. Which of the following means that if you have not been explicitly granted access, then access is denied?
   a. Implicit deny
   b. Explicit deny

c. Allow
d. BPDU

6. What do most public networks, including Wi-Fi hotspots, use to require users to agree to some condition before they use the network or Internet?
   a. PSKs
   b. Proper antenna placement
   c. Appropriate signal power levels
   d. Captive portal

7. Which of the following is a commonly used network zone indicating the highest level of risk where multiple threats are most likely?
   a. Trusted
   b. Untrusted
   c. Screened subnet
   d. Backbone

8. Your supervisor is interested in full automation for the rotation of passwords securing encrypted files at rest belonging to your organization. What security category does this most closely align with?
   a. Content filtering
   b. Device hardening
   c. Network access control
   d. Key management

9. Which of the following are considered secure protocols? (Choose two.)
   a. SSH
   b. FTP
   c. SNMPv1
   d. SNMPv3

This page intentionally left blank